DELIVERABLE 7 — MILESTONE M7

TEST PLAN AND TEST CASES

Code-Sentinel

A Multi-Agent Code Review Platform Built on Service-Oriented Architecture

Document Attribute	Specification
Document ID	CS-QA-M7-2026-v1.0
Course Deliverable	Deliverable 7 (Milestone M7) — Test Plan & Test Cases
Submission Date	06 November 2026 (Week 15)
Client Surfaces in Scope	GitHub App (Webhooks, Checks API & Inline PR Suggestions) and Next.js 16 Web Dashboard
Backend Services in Scope	API Gateway, LangGraph Orchestrator, Security, Style, Performance, Logic & Documentation Agents
Database & Vector Store	PostgreSQL 16 + pgvector on Supabase (18 tables, 9 enums, 768-dim gemini-embedding-2 vectors)
Live Production Deployment	https://codesentinel.scribly.fun (Dashboard) | https://api.codesentinel.scribly.fun (Gateway)
Automated Test Suite Status	67 Test Files | 868 Passing Automated Tests | 100% Pass Rate (Node.js 22 & Node.js 24 CI)

Team Code-Sentinel — QA & Testing Ownership

Team Member	Enrollment No.	Primary Module & Testing / QA Responsibility
Sumit Goyal	202512092	Orchestrator (LangGraph), Parallel Fan-Out, Per-Agent Timeout & LLM Fallback Testing
Durgesh Khushlani	202512051	Finding Aggregation, Deduplication, Severity Ranking & pgvector Similarity Testing
Tej Prakash Tak	202512113	Security Agent (SAST, Secret Detection), Logic Agent & Gateway Rate-Limiting Testing
Nevil Nandasana	202512009	Style Agent (Language Dispatcher, Sandbox) & Prometheus /metrics Endpoint Testing
Parin Makwana	202512098	Performance Agent, Documentation Agent & User Device Sessions API Testing
Ayush Soni	202512030	API Gateway Auth/Routing, PostgreSQL Schema/Migrations, DB Seeding & Audit Log Testing
Vatsal Kamani	202512068	GitHub App Webhooks/Checks API, CI/CD Pipeline, Grafana Alerts & Live E2E PR Testing
Moksh Mehta	202512120	Next.js Web Dashboard UI/UX, Responsive Viewport, Accessibility & Filter Testing

1. Test Strategy, Architecture Under Test & Requirements Traceability

1.1 Purpose and Scope of Testing

This Test Plan and Test Cases document (Deliverable 7, Milestone M7) defines the verification strategy, automated and manual test suites, database seeding dataset, non-functional validation procedures, and defect resolution log for Code-Sentinel. Code-Sentinel is a multi-agent code review platform built on a Service-Oriented Architecture (SOA) in which five stateless specialist agent services — Security, Style, Performance, Logic, and Documentation — analyze pull requests in parallel behind a LangGraph Orchestrator and an Express/TypeScript API Gateway.

In-Scope Components and Surfaces:

- **Two Client Surfaces:** The GitHub App (HMAC-SHA256 webhooks, GitHub Check Runs, inline pull request review comments with committable suggested changes) and the Next.js 16 Web Dashboard (overview, repository configuration, review history, three-panel diff/finding inspector, on-demand review re-runs, SSE live progress, TOTP step-up, and device session management).
- **Seven Backend Microservices:** API Gateway (`@code-sentinel/gateway`), LangGraph Orchestrator (`@code-sentinel/orchestrator`), Security Agent (`:8081`), Style Agent (`:8082`), Performance Agent (`:8083`), Logic Agent (`:8084`), and Documentation Agent (`:8085`).
- **Five Shared Monorepo Packages:** `@code-sentinel/contracts` (Zod schemas, CWE family normalization, deduplication keys, severity ranking), `@code-sentinel/agent-kit` (base agent HTTP server, unified diff parser, brace-balanced patch builder), `@code-sentinel/service-kit` (service auth, Pino correlation logger, Prometheus metrics), `@code-sentinel/llm` (Groq/Gemini fallback client, sliding-window QuotaBudget, 768-dim GeminiEmbedder), and `@code-sentinel/db` (Prisma 6 client, AES-256-GCM SecretBox, 18-table deterministic seed dataset).
- **Data Layer & Vector Store:** PostgreSQL 16 + pgvector on Supabase covering all 18 relational and vector tables, 9 enumerated types, foreign-key cascades, and HNSW/cosine similarity search.

Out-of-Scope Items (Consistent with BRD Section 1.4):

- IDE extensions, non-GitHub version control hosts (GitLab, Bitbucket), automatic branch merging without developer confirmation, and dedicated native mobile apps (the Next.js Web Dashboard is mobile-responsive down to 375px instead).

1.2 Multi-Tier Testing Pyramid & Execution Harness

Code-Sentinel employs a five-tier testing pyramid executed continuously via Vitest 3, Supertest, Prisma integration harnesses, OpenAPI 3.1 schema validators, and browser/observability verification suites.

Testing Tier	Primary Tooling & Harness	Coverage Scope	Verification Focus
Tier 1: Unit & Component Tests	Vitest 3, Node.js 22/24, fast-check / deterministic fixtures	61 unit test files across all 13 workspaces (800+ assertions)	Pure functions, Zod schemas, SAST regex/entropy scanners, AST docstring/complexity parsers, diff hunk parsers, deduplication keys, severity rankers, QuotaBudget sliding windows, and React UI helpers.
Tier 2: Service & REST API Contract Tests	Vitest 3 + Supertest + OpenAPI 3.1 validator (validate_openapi.py)	Gateway, Orchestrator, and all 5 Agent /v1/review HTTP suites	Request/response schema compliance against gateway.yaml, orchestrator.yaml, agent.yaml, and common.yaml; auth guards; TOTP step-up; rate limiters; SSE progress streams.

Testing Tier	Primary Tooling & Harness	Coverage Scope	Verification Focus
Tier 3: Database & Vector Store Integration	Prisma 6 + PostgreSQL 16 + pgvector (schema.integration.test.ts)	All 18 tables, 9 enums, foreign keys, cascades, and HNSW/cosine queries	Migration verification, seedMeaningfulDatabase (88 records across 18 tables), tenant scoping, unique constraints, AES-256-GCM token encryption, and 768-dim vector similarity search.
Tier 4: End-to-End Pipeline & Webhook Tests	Simulated & live GitHub App webhooks + Octokit Checks/Review API	UC-1 (Webhook PR), UC-2 (Manual Re-run), UC-3 (Accept/Reject Fix), UC-4, UC-5	Full review lifecycle from HMAC-verified GitHub webhook receipt through parallel 5-agent fan-out, aggregation, pgvector context enrichment, Check Run creation, and inline suggestion commit.
Tier 5: Non-Functional (UI, Perf, Sec, Obs)	Chrome DevTools, Lighthouse, Prometheus /metrics, Grafana Cloud	52 non-functional test cases (NFT-UI, NFT-PERF, NFT-REL, NFT-SEC, NFT-OBS)	Responsive 375px layout, WCAG AA contrast, P95 <= 60s review latency, 20s agent timeout degradation, 3-tier rate limiting, CSP headers, and Prometheus/Grafana alert rules.

1.3 Continuous Integration & Environment Matrix

Every pull request and push to main runs the GitHub Actions CI pipeline (.github/workflows/ci.yml) across a Node.js 22 and Node.js 24 matrix backed by a live PostgreSQL 16 + pgvector service container (pgvector/pgvector:pg16):

- **Static Analysis & Type Safety:** `npm run lint` (ESLint 9 flat config across all 13 workspaces) and `npm run typecheck` (strict TypeScript 5.8 compilation with zero implicit any).
- **Database Migration & Schema Verification:** Runs `npm run migrate:deploy -w @code-sentinel/db` against a fresh PostgreSQL + pgvector container, then executes `schema.integration.test.ts` and `seed-data.test.ts`.
- **Monorepo Test Execution:** Runs `npm test` via Turborepo across all 67 test files (868 automated test cases).
- **OpenAPI 3.1 Contract Validation:** Executes `python docs/design/build/validate_openapi.py` to validate `gateway.yaml`, `orchestrator.yaml`, `agent.yaml`, and `common.yaml`.

1.4 Requirements Traceability Matrix (RTM)

Table 1.2 maps every Functional Requirement (FR), Non-Functional Requirement (NFR), and Acceptance Criterion (AC) from the Business Requirements Document and System Design Document to its verifying test cases.

Req ID	Requirement Summary	Verifying Test Cases	Status
FR-GW-01	Single REST/JSON entry point for GitHub App & Web Dashboard	API-01..API-23, IT-01	**PASS**
FR-GW-02	Authenticate GitHub App installation tokens & Supabase sessions	UT-36, API-05, NFT-SEC-02	**PASS**
FR-GW-03	Verify HMAC-SHA256 signature of inbound GitHub webhooks before body read	UT-35, API-01, API-02, NFT-SEC-01	**PASS**
FR-GW-04	Route validated review requests to Orchestrator and relay combined report	IT-01, IT-02, API-04, API-08	**PASS**
FR-GW-05	Rate-limit requests per installation, per user, and per IP on failed sign-in	UT-38, API-03, NFT-SEC-08..10	**PASS**

Req ID	Requirement Summary	Verifying Test Cases	Status
FR-ORC-01	Fan out review request to 5 specialist agents in parallel over REST/JSON	UT-28, IT-04, API-24	PASS
FR-ORC-02	Apply configurable per-agent timeout (20s default) and return partial results	UT-29, IT-05, NFT-PERF-02, NFT-REL-01	PASS
FR-ORC-03	Aggregate all agent findings and deduplicate overlapping file/line/rule issues	UT-30, IT-06, BUG-02, BUG-04	PASS
FR-ORC-04	Rank aggregated findings by severity (critical, warning, info) then confidence	UT-31, IT-06	PASS
FR-ORC-05	Query pgvector for semantically similar past issues and attach context	UT-32, IT-07, DB-08, NFT-PERF-06	PASS
FR-ORC-06	Emit suggested-change payload only when confidence >= repository threshold (default 0.80)	UT-33, IT-08, BUG-10	PASS
FR-SEC-01	Statically scan changed code (SAST) for SQLi, XSS, deserialization, path traversal	UT-14, UT-15, API-29	PASS
FR-SEC-02	Detect hardcoded secrets, API keys, and high-entropy tokens in added lines	UT-16, BUG-05	PASS
FR-SEC-03	Return each security finding with severity level, CWE ID, and confidence score	UT-17, API-29	PASS
FR-SEC-04	Expose Security Agent findings via standalone reusable REST/JSON API	API-29, API-30, NFT-REL-08	PASS
FR-STY-01	Detect language of changed file and dispatch to ESLint/Prettier or Ruff/Black	UT-18, UT-19, API-31	PASS
FR-STY-02	Execute linters and formatters inside isolated, resource-limited sandbox	UT-20, NFT-SEC-12, BUG-12	PASS
FR-STY-03	Automatically compute deterministic style/formatting fixes with zero LLM calls	UT-21, NFT-REL-05	PASS
FR-STY-04	Report non-auto-fixable lint violations as standard findings in combined report	UT-19, API-31	PASS
FR-PERF-01	Flag N+1 query patterns, blocking sync calls on async paths, and O(n^2) loops	UT-22, UT-23, API-32	PASS
FR-PERF-02	Return performance findings within per-agent timeout for typical diffs (<500 lines)	UT-23, NFT-PERF-02	PASS
FR-LOG-01	Analyze changed code for null/undefined dereferences, off-by-one, unhandled errors	UT-24, UT-25, API-33	PASS
FR-LOG-02	Use shared LLM abstraction layer and fall back automatically on provider error/quota	UT-09..11, IT-09, NFT-REL-02	PASS
FR-DOC-01	Check touched public functions/classes for docstrings/JSDoc parameter & return coverage	UT-26, UT-27, API-34	PASS
FR-DOC-02	Generate suggested docstring content as non-blocking info finding	UT-27, API-34	PASS
FR-GH-01	Subscribe to pull_request webhooks (opened, synchronize, reopened, closed)	IT-10, API-01, BUG-07	PASS
FR-GH-02	Post combined review report as GitHub Check Run with pass/fail/neutral conclusion	UT-41, IT-11, NFT-UI-15	PASS
FR-GH-03	Post high-confidence findings as inline PR review comments with suggested change	UT-41, IT-12, NFT-UI-16	PASS
FR-GH-04	Never modify PR branch directly without explicit developer commit action	API-11..13, IT-13, NFT-SEC-04	PASS

Req ID	Requirement Summary	Verifying Test Cases	Status
FR-WEB-01	Display organization-scoped review history across installed repositories	API-06, NFT-UI-01..04	PASS
FR-WEB-02	Allow Repository Admin to enable/disable individual agents per repository	API-16, API-17, NFT-UI-09	PASS
FR-WEB-03	Allow Repository Admin to override default 80% confidence threshold per repository	API-16, API-17, NFT-UI-10	PASS
FR-WEB-04	Display combined review report detail view filterable by agent and severity	API-08, NFT-UI-05..08	PASS
FR-VDB-01	Store 768-dim pgvector embeddings of flagged findings in finding_embeddings	UT-32, DB-07, IT-07	PASS
FR-VDB-02	Retrieve semantically similar past issues (cosine >= 0.80) and attach to report	UT-32, DB-08, IT-07	PASS
NFR-01	End-to-end combined review for typical PR (<500 lines) completes within P95 <= 60s	NFT-PERF-01	PASS
NFR-02	Configurable per-agent timeout (default 20s) with partial result progression	NFT-PERF-02, NFT-REL-01	PASS
NFR-03	Independent horizontal scalability across >= 10 concurrent review jobs	NFT-PERF-04	PASS
NFR-04	Graceful degradation when one agent fails or times out (partial = success state)	IT-05, NFT-REL-01..04	PASS
NFR-05	HTTPS/TLS, HMAC-SHA256 webhook verification, AES-256-GCM encrypted tokens at rest	NFT-SEC-01, NFT-SEC-07, DB-03	PASS
NFR-06	Diff-scoped & budget-bounded LLM context (drop binaries/lockfiles, cap file size)	UT-12, UT-34, NFT-PERF-05	PASS
NFR-07	100% deterministic, zero-LLM Style Agent auto-fixes inside isolated sandbox	UT-21, NFT-REL-05	PASS
NFR-08	Consistent severity tokens, terminology, and counts across GitHub PR & Web Dashboard	NFT-UI-15, NFT-UI-16	PASS
NFR-09	Web Dashboard responsive and usable down to 375px mobile viewport	NFT-UI-11, NFT-UI-12	PASS
NFR-10	Independent OpenAPI 3.1 REST contract per agent service (SOA loose coupling)	API-29..34, NFT-REL-08	PASS
NFR-11	Provider-agnostic LlmClient running across Groq (gpt-oss-120b) & Gemini 3.5 Flash Lite	UT-09..11, NFT-REL-02	PASS
NFR-12	Per-run agent latency, provider, fallback depth, and failure reason logged & exposed	DB-05, NFT-OBS-01..05	PASS
NFR-13	Strict per-organization and per-repository tenant data isolation (cross-org returns 404)	API-09, NFT-SEC-05, NFT-SEC-06	PASS
NFR-14	Sliding-window & 24h QuotaBudget (80% free-tier cap) preventing production 429s	UT-10, NFT-REL-03	PASS
AC-01..AC-13	All 13 Given/When/Then BRD Acceptance Criteria verified end-to-end	IT-01..IT-22, NFT-UI-01..16	PASS

2. Unit, Integration, and API Functional Test Cases

2.1 Automated Test Suite Inventory Across Monorepo Workspaces

The Code-Sentinel monorepo contains 67 automated test files comprising 868 individual test cases across all 13 workspaces (5 shared packages, 7 backend microservices, and 1 Next.js web application). Every test suite runs deterministically without external network dependencies during CI.

Workspace Package	Directory	Files	Tests	Primary Functional Coverage
`@code-sentinel/contracts`	packages/contracts	3	67	Zod schemas, CWE family normalization, severity ranking, dedupe key hashing, OpenAPI example payloads
`@code-sentinel/agent-kit`	packages/agent-kit	4	48	BaseAgentService HTTP lifecycle, unified diff parser, brace-balanced patch builder, LLM JSON parser
`@code-sentinel/service-kit`	packages/service-kit	3	35	HMAC/Bearer internal service auth, Pino correlation logger, Prometheus /metrics registry & pre-zeroed counters
`@code-sentinel/llm`	packages/llm	3	31	LlmClient Groq->Gemini fallback, QuotaBudget 1m/24h reservation, GeminiEmbedder 768-dim vectors
`@code-sentinel/db`	packages/db	3	16	AES-256-GCM token crypto, 18-table deterministic seed builder (seed-data.test.ts), PostgreSQL + pgvector integration
`@code-sentinel/security-agent`	services/security-agent	4	67	SAST ruleset (SQLi, XSS, cmdi, path traversal, weak crypto), regex + Shannon entropy secret scanner, CWE dedupe
`@code-sentinel/style-agent`	services/style-agent	4	55	Language dispatcher (.ts/.js/.py), ESLint, Prettier, Ruff, Black, ProcessSandbox & DockerSandbox isolation
`@code-sentinel/performance-agent`	services/performance-agent	2	36	Hot-path AST heuristics (N+1 queries in loops, sync fs/crypto in async handlers, nested loops) + LLM pass
`@code-sentinel/logic-agent`	services/logic-agent	2	31	Edge-case static pre-checks (unchecked array index, missing switch default, float equality) + LLM pass
`@code-sentinel/documentation-agent`	services/documentation-agent	2	33	Exported TS/JS & Python symbol parser, docstring coverage detector, deterministic + LLM docstring generator
`@code-sentinel/orchestrator`	services/orchestrator	11	117	LangGraph StateGraph fan-out, per-agent timeout, large-diff planner, aggregator, pgvector context, sleeping health
`@code-sentinel/gateway`	services/gateway	20	292	GitHub webhook HMAC, Octokit Checks/PR comments, JWT/session auth, TOTP step-up, apply-fix, rate limits, SSE, audit
`@code-sentinel/dashboard`	apps/dashboard	6	40	Next.js 16 server/client API proxies, dynamic env resolution, relative time formatting, severity/agent view helpers
TOTAL	**13 Workspaces**	**67**	**868**	**100% pass rate in GitHub Actions CI across Node.js 22 and Node.js 24**

2.2 Detailed Unit Test Cases (UT-01 to UT-40)

Table 2.2 catalogues the core unit test cases verifying shared libraries, static analyzers, AST parsers, sandbox dispatchers, LangGraph nodes, LLM quota budgets, and cryptographic utilities.

Test ID	Module & Test File	Test Objective	Input / Fixture	Expected Outcome	Status
UT-01	contracts (schemas.test.ts)	Validate Finding, Suggestion, and CombinedReport Zod schemas against valid and malformed payloads	Valid/invalid JSON fixtures for all 9 enums and nested report objects	Valid payloads parse cleanly; out-of-range confidence (<0 or >1) or invalid UUIDs throw ZodError	PASS
UT-02	contracts (cwe.test.ts)	Normalize sibling CWE identifiers into canonical CWE families via cweFamilyOf()	CWE-89 & CWE-564 (SQLi), CWE-79 & CWE-80 (XSS), CWE-22 & CWE-23 (Path Traversal)	Sibling CWEs map to identical canonical family keys so intra-agent and cross-agent deduplication collapses them	PASS
UT-03	contracts (ranking.test.ts)	Compute deterministic severityRank and sort findings by severity then confidence descending	Mixed array of info (0.99), critical (0.81), warning (0.95), critical (0.94) findings	Ordered strictly: critical (0.94), critical (0.81), warning (0.95), info (0.99)	PASS
UT-04	contracts (dedupe.test.ts)	Generate stable SHA-256 deduplication keys across agents flagging the same code construct	File path, overlapping line spans (lines 42-45 vs 43-45), and rule/CWE family	Identical normalized dedupeKey produced for overlapping spans in same CWE/rule family	PASS
UT-05	agent-kit (diff.test.ts)	Parse unified GitHub patch hunks and map added line numbers to full-file coordinates	Multi-hunk unified diff with context lines, deletions, additions, and no-newline markers	Accurate 1-indexed added line set and line-content map; deleted lines excluded from findings	PASS
UT-06	agent-kit (patch.test.ts)	Balance braces and apply multi-line replacements cleanly to changed files	Partial JS/TS hunk with unbalanced braces and multi-line replacement snippet	Brace-balancing recovery wraps partial snippet cleanly; applyReplacement updates exact target lines	PASS
UT-07	agent-kit (http.test.ts)	Enforce BaseAgentService request validation, bearer token auth, and skipped-file size limits	POST /v1/review with oversized file (>maxFileTokens) and missing bearer token	Missing token returns 401; oversized file is returned in skippedFiles[] with reason over_budget without splitting	PASS
UT-08	service-kit (metrics.test.ts)	Pre-initialize Prometheus counters to 0 at startup and record HTTP/LLM/review histograms	Fresh ServiceMetrics instance scraped via GET /metrics before any traffic	All alert counter label combinations (agent_failures, quota_events, webhook_errors) emit 0 so Grafana increase() detects first event	PASS
UT-09	llm (llm-client.test.ts)	Route small batches to Groq (openai/gpt-oss-120b) and fall back to Gemini 3.5 Flash Lite on error	Primary Groq mock returning 503/timeout; secondary Gemini mock returning valid JSON	LlmClient retries once on Gemini, returns response with provider='gemini' and llmFallbackDepth=1	PASS
UT-10	llm (quota-budget.test.ts)	Enforce 80% free-tier sliding 1-minute and rolling 24-hour request/token reservations	Groq budget (24 RPM, 6.4K TPM, 800 RPD, 160K TPD effective caps) under burst load	Reservations exceeding 6.4K TPM defer to Gemini or wait until window slides; settleReservation adjusts actual tokens	PASS
UT-11	llm (gemini-embedder.test.ts)	Generate 768-dimension float embeddings via gemini-embedding-2 and handle deadline AbortSignal	Batch of 4 finding summaries + caller AbortSignal	Returns 4 L2-normalized 768-float vectors; aborts immediately when caller signal fires	PASS

Test ID	Module & Test File	Test Objective	Input / Fixture	Expected Outcome	Status
UT-12	db (crypto.test.ts)	Encrypt and decrypt GitHub OAuth tokens using AES-256-GCM with random 96-bit IV	Plaintext gho_ token, 32-byte key, and tampered ciphertext/authTag	Round-trip decrypts to exact plaintext; 1-bit flip in ciphertext or authTag throws authentication error	PASS
UT-13	db (seed-data.test.ts)	Verify deterministic 768-dim vector clustering and repository override parsing for DB seed	Cluster 0 vs Cluster 1 embeddings; CODE_SENTINEL_SEED_REPO='octo-org/octo-repo#999'	Intra-cluster cosine similarity > 0.90; cross-cluster < 0.25; repo override parses owner, name, and repoId	PASS
UT-14	security-agent (sast.test.ts)	Detect SQL injection (CWE-89), XSS (CWE-79), command injection (CWE-78), and path traversal (CWE-22)	Vulnerable Python & TypeScript diffs containing string-interpolated SQL, innerHTML, child_process.exec	Flags exact added lines with critical/warning severity, matching CWE ID, and >= 0.85 confidence	PASS
UT-15	security-agent (sast.test.ts)	Detect insecure deserialization (pickle.loads, yaml.load) and weak cryptography (MD5/SHA1, Math.random)	Python diff using yaml.load() without SafeLoader and TS token generator using Math.random()	Flags CWE-502 (critical) and CWE-338/CWE-327 (warning) with safe replacement suggestions	PASS
UT-16	security-agent (scan.test.ts)	Detect hardcoded AWS keys, Stripe live secrets, GitHub PATs, private keys, and high-entropy strings with redaction	Diff adding sk_live_51N... and AKIAIOSFODNN7EXAMPLE in config.py	Flags CWE-798 (critical, confidence 0.96) and masks raw secret literal in finding title/description	PASS
UT-17	security-agent (agent.test.ts)	Deduplicate overlapping SAST and LLM security findings sharing the same CWE family	SAST flags CWE-89 on line 18; LLM flags CWE-564 on line 19 of same query	Collapsed into a single critical finding retaining the highest confidence and AI-suggested parameterized query fix	PASS
UT-18	style-agent (dispatcher.test.ts)	Route changed files by extension to ESLint/Prettier (.ts, .tsx, .js) or Ruff/Black (.py)	Mixed PR containing src/index.ts, apps/web/view.tsx, scripts/etl.py, and README.md	Dispatches TS/TSX to ESLint+Prettier, Python to Ruff+Black, and marks README.md as unsupported language	PASS
UT-19	style-agent (linters.test.ts)	Parse ESLint/Ruff JSON diagnostics and filter findings strictly to lines added in the PR diff	Whole file with legacy lint warnings on line 5 and new unused variable on added line 42	Emits finding only for added line 42; legacy untouched lines are ignored	PASS
UT-20	style-agent (sandbox.test.ts)	Isolate linter execution in ProcessSandbox and DockerSandbox with strict timeout and cleanup	Linter invocation with per-request temp dir and simulated runaway process	Temp directory is wiped after execution; timed-out process is killed cleanly without leaking descriptors	PASS
UT-21	style-agent (agent.test.ts)	Produce deterministic fixKind='deterministic' suggestions with zero LLM invocations	Unformatted Python & TypeScript files with quote/indent/import-order violations	Emits deterministic suggestedCode patches with confidence 1.0 and 0 LLM calls	PASS
UT-22	performance-agent (heuristics.test.ts)	Detect N+1 async queries inside loops, synchronous fs/crypto calls on hot paths, and nested O(n^2) loops	TS handler calling await prisma.user.findUnique() inside for..of loop and fs.readFileSync()	Flags PERF-N-PLUS-ONE (critical/warning) and PERF-SYNC-IO with batched query / async fs fix suggestions	PASS
UT-23	performance-agent (agent.test.ts)	Combine static performance heuristics with LLM hot-path analysis and filter to added lines	Python retry worker with unbounded while True loop and unbatched network calls	Produces ranked findings with confidence scores and bounded-retry suggested fix	PASS

Test ID	Module & Test File	Test Objective	Input / Fixture	Expected Outcome	Status
UT-24	logic-agent (heuristics.test.ts)	Detect unchecked nullable dereferences, off-by-one loop bounds (<= length), and floating-point === comparisons	TS function indexing items[items.length] and comparing currency totals with ===	Flags LOG-OFF-BY-ONE and LOG-FLOAT-EQUALITY on added lines with high confidence	PASS
UT-25	logic-agent (agent.test.ts)	Identify race conditions, swallowed exceptions, and missing return paths via Logic Agent LLM pass	Async payment retry handler catching Exception and silently passing without dead-letter release	Emits warning/critical logic findings with structured suggestedCode replacement	PASS
UT-26	documentation-agent (parser.test.ts)	Extract exported TypeScript functions/classes/methods and public Python defs/classes lacking docstrings	TS file with exported async function chargeCustomer(amount, currency) without JSDoc	Identifies missing JSDoc on exported symbol and flags missing @param and @returns tags	PASS
UT-27	documentation-agent (agent.test.ts)	Generate non-blocking info severity docstring suggestions for undocumented public APIs	Python module adding public enqueue_retry(self, job: Job) without PEP-257 docstring	Emits severity='info' finding with complete PEP-257 docstring suggestion above confidence threshold	PASS
UT-28	orchestrator (fan-out.test.ts)	Fan out POST /v1/review in parallel to all enabled agents and skip disabled agents	Repository config with 4 agents enabled and Documentation Agent disabled	Invokes 4 agents concurrently via Promise.allSettled; records Documentation Agent as status='skipped'	PASS
UT-29	orchestrator (timeout.test.ts)	Enforce per-agent deadline (e.g. 20s) so a slow agent yields status='timed_out' and review completes as 'partial'	4 agents respond in 120ms; Logic Agent delays past perAgentTimeoutMs	Orchestrator aborts slow agent call, records AgentRun(status='timed_out'), and returns CombinedReport(status='partial')	PASS
UT-30	orchestrator (finding-aggregator.test.ts)	Collapse duplicate findings reported by multiple agents on overlapping or +/-2 adjacent lines	Security Agent and Logic Agent both flag missing webhook signature check on lines 34-36	Aggregator keeps higher-severity/higher-confidence primary finding and links secondary via duplicateOf	PASS
UT-31	orchestrator (threshold.test.ts)	Strip auto-suggested fix payloads from findings below repository confidenceThreshold while keeping the finding	Repository threshold 0.80; finding A (confidence 0.91 with fix), finding B (confidence 0.72 with fix)	Finding A retains suggestion; Finding B appears in report with suggestion=null and increments heldBackCount	PASS
UT-32	orchestrator (context-node.test.ts)	Embed new findings via GeminiEmbedder and attach historical similarIssues above 0.80 cosine threshold	New SQLi finding vector queried against pgvector store containing resolved PR #418 finding (score 0.91)	Attaches similarIssues=[{findingId, prNumber: 418, title, similarity: 0.91, resolution: 'accepted'}]	PASS
UT-33	orchestrator (planner.test.ts)	Group changed files by local import graph and downgrade oversized files (>12K tokens) to diff-only	PR with 8 files importing shared utils, 1 generated lockfile, 1 15K-token file, and 1 90K-token file	Drops lockfile, groups related files into 1 LLM call, marks 15K file diff-only, marks 90K file over_budget	PASS
UT-34	orchestrator (agents-health.test.ts)	Classify sleeping free-tier Render agent services as 'sleeping' rather than 'down'	Agent health probe returning Render idle/wake headers or cold-start status	Returns overall='sleeping' so dashboard displays calm 'Asleep (wakes on next review)' notice	PASS

Test ID	Module & Test File	Test Objective	Input / Fixture	Expected Outcome	Status
UT-35	gateway (github-webhook.test.ts)	Verify X-Hub-Signature-256 using crypto.timingSafeEqual against raw request buffer before JSON parsing	Valid HMAC-SHA256 signature, tampered payload body, and wrong secret	Valid signature proceeds; tampered body or wrong secret returns 401 invalid_signature immediately	PASS
UT-36	gateway (auth-middleware.test.ts)	Verify Supabase ES256/HS256 JWTs and confirm active session existence in Supabase Auth	Valid JWT with active session, expired JWT, and valid JWT whose session was signed out	Active session attaches req.auth; revoked session or expired JWT returns 401 unauthorized	PASS
UT-37	gateway (step-up.test.ts)	Enforce conditional TOTP step-up (aal2 or X-Totp-Code) only when user has enrolled an authenticator	User A (enrolled TOTP, aal1 token), User B (enrolled TOTP, valid 6-digit code), User C (no TOTP enrolled)	User A receives 403 step_up_required; User B and User C succeed and audit event records stepUpUsed accurately	PASS
UT-38	gateway (rate-limit.test.ts)	Enforce per-installation webhook limit, per-user API limit, and per-IP failed auth limit with Retry-After	Burst requests exceeding configured window threshold	Returns HTTP 429 Too Many Requests with Retry-After header and rate_limit_exceeded error code	PASS
UT-39	gateway (apply-all-fixes.test.ts)	Filter and apply non-overlapping proposed suggestions in a single atomic Git commit on PR head branch	3 proposed fixes: 2 non-overlapping in config.py & retry.py, 1 overlapping line range	Applies the 2 non-overlapping fixes in one commit, marks them accepted, and reports accurate applicable count	PASS
UT-40	dashboard (env-and-ui.test.ts)	Resolve GATEWAY_URL dynamically at request time and format deterministic UTC/relative timestamps	Runtime env mutation and SSR/CSR timestamp hydration fixtures	Reads updated GATEWAY_URL without rebuild; renders hydration-safe timestamps and severity badges	PASS

2.3 Service-to-Service Integration Test Cases (IT-01 to IT-18)

Integration tests verify cross-component workflows across the API Gateway, LangGraph Orchestrator, the five specialist Agent HTTP services, PostgreSQL + pgvector persistence, Octokit GitHub API adapters, and Supabase Auth session/TOTP verification.

Test ID	Workflow / Use Case	Scenario Description	Participating Components	Expected End-to-End Outcome	Status
IT-01	Webhook -> Gateway -> Orchestrator -> 5 Agents (UC-1 Happy Path)	Inbound pull_request.opened webhook triggers full parallel review across all 5 agents and persists CombinedReport	Gateway, Orchestrator, 5 Agent services, PostgreSQL + pgvector, mock Octokit	HTTP 202 returned in <500ms; Check Run created; 5 agent_runs, deduplicated findings, suggestions, and 768-dim embeddings persisted; Check Run updated with final conclusion	PASS
IT-02	Webhook Idempotency on Redelivery	Duplicate X-GitHub-Delivery header or identical (repositoryId, prNumber, headSha) does not spawn a duplicate review job	Gateway + Orchestrator + PostgreSQL reviews unique constraint	Second delivery returns existing reviewId/jobId with HTTP 200/202; only 1 row exists in reviews table	PASS
IT-03	Superseding In-Flight Review on New Push	pull_request.synchronize webhook while an older review is running cancels the old job and marks its open suggestions superseded	Gateway + Orchestrator cancellation endpoint + PostgreSQL suggestions table	Old review transitions to cancelled; old proposed suggestions transition to state='superseded'; new review starts for new headSha	PASS

Test ID	Workflow / Use Case	Scenario Description	Participating Components	Expected End-to-End Outcome	Status
IT-04	Parallel Fan-Out & Independent Agent Execution	Orchestrator fans out to Security, Style, Performance, Logic, and Documentation agents concurrently	Orchestrator StateGraph + 5 HTTP agent servers	Total fan-out wall time equals slowest responding agent (~1.8s in test harness), not sum of all 5 agents	PASS
IT-05	Partial Review on Single Agent Timeout (UC-1 Alternate Flow)	Logic Agent exceeds 20s timeout while Security, Style, Performance, and Documentation succeed	Orchestrator + 4 healthy agents + 1 delayed agent	Review completes with status='partial'; Logic agent_run recorded as status='timed_out' with latencyMs=20000; Check Run states gap clearly	PASS
IT-06	Cross-Agent Deduplication & Severity Ranking Pipeline	Security Agent and Performance Agent flag the same line range; Orchestrator merges, ranks, and preserves provenance	Orchestrator aggregateNode + PostgreSQL findings table	Primary finding stored with duplicateOf=null; duplicate finding linked via duplicateOf=primary.id; report lists only primary finding	PASS
IT-07	pgvector Embedding Persistence & Historical Similarity Lookup	New findings are embedded via GeminiEmbedder (768-dim) and matched against prior resolved findings in same organization	Orchestrator contextNode + PostgreSQL finding_embeddings & finding_similarities	Cosine similarity query retrieves matching past finding (>= 0.80), inserts finding_similarities row, and attaches similarIssues[] to report	PASS
IT-08	Confidence Threshold Filtering & Held-Back Suggestion Accounting	Repository override sets confidenceThreshold=0.85; findings with confidence 0.82 keep finding card but drop auto-suggestion	Orchestrator thresholdNode + Gateway review-output formatter	Finding with 0.82 confidence has suggestion=null; Check Run summary accurately reports 1 suggestion held back below 85% threshold	PASS
IT-09	LLM Primary-to-Secondary Fallback & Quota Deferral	Groq primary returns 429/503 or hits 80% TPM cap; LlmClient seamlessly routes batch to Gemini 3.5 Flash Lite	Agent services + @code-sentinel/llm + Orchestrator agent_runs persistence	Review succeeds without error; agent_runs row records llmProvider='gemini' and llmFallbackDepth=1	PASS
IT-10	Dashboard On-Demand Review Re-Run & 30s Cooldown (UC-2)	Authenticated user triggers POST /v1/reviews from dashboard; immediate repeat call within 30s is rejected	Dashboard API proxy -> Gateway -> Orchestrator -> PostgreSQL	First call creates review with trigger='dashboard_manual' (HTTP 202); second call within 30s returns HTTP 409 review_cooldown_active	PASS
IT-11	SSE Live Review Progress Streaming	Dashboard subscribes to GET /v1/reviews/{reviewId}/events while agents complete asynchronously	Gateway SSE endpoint + Orchestrator job progress store	Client receives real-time agent_run status transitions (pending -> running -> succeeded/timed_out) and final completed event	PASS
IT-12	Accept Single Suggestion & Commit to PR Branch (UC-3)	User accepts a proposed fix with valid step-up auth; Gateway verifies PR head/lines unchanged and commits via Octokit	Gateway accept endpoint + Octokit Git Data/Contents API + PostgreSQL	Git commit written to PR head branch; suggestion state='accepted', resolvedByUserId and githubCommitSha saved; audit event logged	PASS

Test ID	Workflow / Use Case	Scenario Description	Participating Components	Expected End-to-End Outcome	Status
IT-13	Accept Suggestion Conflict Detection (Stale Head, Fork PR, Already Decided)	Accepting a fix when PR head moved, PR is from a fork, or suggestion was already accepted/rejected	Gateway accept endpoint + Octokit PR metadata check	Returns HTTP 409 Conflict (stale_branch_head, fork_pull_request, or suggestion_already_resolved) without modifying branch	PASS
IT-14	Reject Suggestion with Reason & Reviewer Comment (UC-3 Alternate)	User dismisses a suggestion with reason='false_positive' and comment; Gateway resolves GitHub thread	Gateway reject endpoint + Octokit + PostgreSQL suggestions table	Suggestion updated to state='rejected', rejectionReason='false_positive', rejectionComment saved; audit event recorded	PASS
IT-15	Batch Apply All Non-Overlapping Fixes	User clicks 'Apply all fixes' on a review with multiple deterministic and high-confidence AI suggestions	Gateway POST /v1/reviews/{reviewId}/suggestions/accept-all + Octokit	All applicable non-overlapping fixes committed in a single branch commit; each suggestion marked accepted with shared commit SHA	PASS
IT-16	Repository Configuration & Agent Toggle Persistence (UC-4)	Admin updates per-agent enable flags and confidenceThreshold override; trying to disable all 5 agents is blocked	Gateway PUT /v1/repositories/{id}/config + PostgreSQL repository_settings & repository_agent_config	Valid config persists and applies to next review job; disabling all 5 agents returns HTTP 400 no_agents_enabled	PASS
IT-17	Strict Organization & Repository Member Tenant Isolation	Organization A user queries Organization B review/repo, or org member queries unpermitted private repo	Gateway tenant guards + PostgreSQL organization_members & repository_members	Cross-org access returns HTTP 404 Not Found; member without repository_members row cannot see unpermitted repo	PASS
IT-18	Signed-In Devices Listing & Remote Session Revocation	User lists active sessions via GET /v1/me/sessions and revokes a secondary device via DELETE /v1/me/sessions/{id}	Gateway sessions router + Supabase private.user_sessions() + session_activity + audit_events	Lists IP, parsed browser/OS, and lastSeenAt; revoking deletes Supabase session and writes session.revoked audit event	PASS

2.4 REST API Contract & Endpoint Test Cases (API-01 to API-29)

Every REST endpoint specified in docs/design/openapi/gateway.yaml, orchestrator.yaml, and agent.yaml is tested for positive responses, schema validation, authentication/authorization guards, TOTP step-up enforcement, organization/repository tenant isolation, idempotency, and rate limiting.

Test ID	HTTP Method & Endpoint	Request Scenario & Headers	Expected HTTP	Response Payload & Side-Effect Verification	Status
API-01	POST /webhooks/github	Valid HMAC-SHA256 signature + pull_request.opened payload	202 Accepted	Creates queued review row, dispatches job to Orchestrator, posts initial GitHub Check Run	PASS
API-02	POST /webhooks/github	Missing or invalid X-Hub-Signature-256 header	401 Unauthorized	Returns {error: 'invalid_signature'} before parsing JSON body; increments webhook auth failure metric	PASS

Test ID	HTTP Method & Endpoint	Request Scenario & Headers	Expected HTTP	Response Payload & Side-Effect Verification	Status
API-03	POST /webhooks/github	Installation exceeds 60 webhook requests/minute rate limit	429 Too Many Requests	Returns Retry-After header and {error: 'rate_limit_exceeded'}; logs rate_limit.exceeded audit event	PASS
API-04	POST /v1/reviews	Authenticated member triggers manual review on open PR	202 Accepted	Returns {reviewId, status: 'queued', trigger: 'dashboard_manual'}	PASS
API-05	POST /v1/reviews	PR is closed, reviews disabled on repo, or review started <30s ago	409 Conflict	Returns descriptive error code (pr_not_open, reviews_disabled, or review_cooldown_active)	PASS
API-06	GET /v1/reviews	Filter by repositoryId, status='partial', severity='critical', trigger, page, pageSize	200 OK	Returns paginated items[] scoped to caller's organization with total count and finding summary counts	PASS
API-07	GET /v1/reviews	Missing or expired Bearer access token	401 Unauthorized	Returns {error: 'unauthorized'}; records auth.failed audit event with client IP	PASS
API-08	GET /v1/reviews/{reviewId}	Fetch full CombinedReport with optional ?agent=security filter	200 OK	Returns review metadata, agentRuns[], ranked findings[], suggestions, coverage, and similarIssues[]	PASS
API-09	GET /v1/reviews/{reviewId}	reviewId belongs to a different organization (cross-tenant access attempt)	404 Not Found	Returns 404 (never 403) so resource existence is not leaked across organizations	PASS
API-10	GET /v1/reviews/{reviewId}/events	Subscribe to Server-Sent Events stream for running review	200 OK (text/event-stream)	Streams progress events as each agent finishes and closes cleanly on terminal review status	PASS
API-11	POST /v1/findings/{id}/suggestion/accept	Accept fix with valid step-up TOTP code (when enrolled) on unchanged PR branch	200 OK	Commits patch to GitHub PR branch, returns {state: 'accepted', commitSha}, logs suggestion.accepted	PASS
API-12	POST /v1/findings/{id}/suggestion/accept	User has TOTP enrolled but omits X-Totp-Code and session is aal1	403 Forbidden	Returns {error: 'step_up_required', message: 'Enter your authenticator code to commit fixes'}	PASS
API-13	POST /v1/findings/{id}/suggestion/accept	Suggestion already resolved, superseded by newer push, or PR is from a fork	409 Conflict	Returns {error: 'suggestion_not_applicable'} without calling GitHub commit API	PASS
API-14	POST /v1/findings/{id}/suggestion/reject	Dismiss suggestion with reason='wont_fix_manually' and comment	200 OK	Updates suggestion to state='rejected', saves comment, logs suggestion.rejected audit event	PASS

Test ID	HTTP Method & Endpoint	Request Scenario & Headers	Expected HTTP	Response Payload & Side-Effect Verification	Status
API-15	POST /v1/reviews/{id}/suggestions/accept-all	Batch commit all non-overlapping proposed suggestions for a review	200 OK	Commits combined file changes in one Git commit and returns {appliedCount, commitSha}	PASS
API-16	GET /v1/repositories	List repositories accessible to caller (admin sees all org repos; member sees repository_members subset)	200 OK	Returns repositories[] with effective reviewEnabled, confidenceThreshold, and latest review summary	PASS
API-17	GET /v1/repositories/{id}/config	Read effective per-agent config and value provenance (repo override vs org default vs platform default)	200 OK	Returns {confidenceThreshold, thresholdSource, agentTimeoutSeconds, agents: {security..documentation}}	PASS
API-18	PUT /v1/repositories/{id}/config	Admin updates agent flags and sets confidenceThreshold=0.85 (with step-up if enrolled)	200 OK	Upserts repository_settings & repository_agent_config, updates updatedByUserId, logs repo_config.updated	PASS
API-19	PUT /v1/repositories/{id}/config	Non-admin member attempts to modify repository configuration	403 Forbidden	Returns {error: 'admin_required'}; configuration remains unchanged	PASS
API-20	PUT /v1/repositories/{id}/config	Admin attempts to disable all 5 specialist agents simultaneously	400 Bad Request	Returns {error: 'no_agents_enabled', message: 'At least one agent must remain enabled'}	PASS
API-21	GET /v1/me	Fetch authenticated user profile, organization memberships, roles, and hasAuthenticator flag	200 OK	Returns user details, organizations[], and mfaEnabled boolean	PASS
API-22	GET /v1/me/sessions & DELETE /v1/me/sessions/{id}	List active Supabase sessions with device/IP and sign out a specific session	200 OK / 204 No Content	Returns active devices list; DELETE revokes target session and writes session.revoked audit event	PASS
API-23	GET /v1/audit-events	Admin queries organization security audit trail with action and date filters	200 OK	Returns paginated audit_events with actor, action, ipAddress, userAgent, requestId, and metadata	PASS
API-24	POST /internal/v1/review-jobs (Orchestrator)	Gateway submits asynchronous review job with Idempotency-Key header	202 Accepted	Starts LangGraph review workflow and returns {jobId, status: 'queued'}	PASS
API-25	GET /internal/v1/review-jobs/{jobId} (Orchestrator)	Gateway polls in-flight or completed review job state	200 OK	Returns current job status, per-agent progress, and CombinedReport when complete	PASS
API-26	POST /internal/v1/review-jobs/{jobId}/cancel (Orchestrator)	Gateway cancels running job when PR is closed or superseded	200 OK	Aborts in-flight agent HTTP requests and transitions job to status='cancelled'	PASS
API-27	GET /internal/v1/agents/health (Orchestrator)	Probe live health, latency, version, and sleeping status of all 5 agents	200 OK	Returns per-agent status ('ok' | 'degraded' | 'sleeping' | 'down') and latencyMs	PASS

Test ID	HTTP Method & Endpoint	Request Scenario & Headers	Expected HTTP	Response Payload & Side-Effect Verification	Status
API-28	POST /v1/review (All 5 Agent Services)	Orchestrator sends changed files, diff hunks, and context to Security/Style/Perf/Logic/Doc agents	200 OK	Each agent returns {agent, findings[], skippedFiles[], latencyMs, llmProvider, llmFallbackDepth}	PASS
API-29	GET /v1/capabilities & GET /healthz & GET /metrics	Service discovery, readiness probes, and Prometheus scrape across all 7 backend services	200 OK	Capabilities returns supported languages & maxFileTokens; /healthz returns {status:'ok'}; /metrics returns Prometheus text format	PASS

3. Populating the Database with Meaningful Records

3.1 Seeding Strategy, Determinism & Referential Integrity

To support local development, dashboard UI verification, API integration testing, and live demonstrations, @code-sentinel/db provides an idempotent, deterministic database seeding module in packages/db/src/seed-data.ts (invoked via npm run db:seed -w @code-sentinel/db or prisma db seed). Key engineering properties of the seed dataset include:

- **100% Schema Coverage (All 18 Tables & 9 Enums):** Populates 88 interconnected records across every single table in packages/db/prisma/schema.prisma, exercising every enum state (queued, running, completed, partial, failed, cancelled; proposed, accepted, rejected, superseded; block, comment, off).
- **Cross-Workspace UUID Alignment:** `SEED_IDS` preserves the exact canonical UUIDs used in `@code-sentinel/contracts/examples` and `services/gateway/src/persistence/dev-seed.ts` (e.g., Organization `7d9e1f2a-3b4c-4d5e-8f60-718293a4b5c6`, Repository `2b0c6b0e-0b1a-4f6e-9c3d-1a2b3c4d5e6f`).
- **AES-256-GCM Sealed OAuth Tokens:** GitHub user tokens in `github_user_tokens` are encrypted at rest via `SecretBox` before insertion so plaintext credentials never touch disk.
- **Semantic 768-Dimension pgvector Clusters:** `buildDeterministicEmbedding(cluster, variant)` generates L2-normalized 768-float vectors stored via raw SQL `::vector(768)` casts in `finding_embeddings`. Intra-cluster cosine similarity exceeds 0.88 (e.g., 0.924 between PR #48 and PR #42 SQL injection findings), while cross-cluster similarity stays below 0.20.

3.2 Complete 18-Table Inventory & Seeded Record Counts

Table 3.1 lists all 18 PostgreSQL tables in packages/db/prisma/schema.prisma, their domain group, the exact number of seeded rows, and the representative records populated by seedMeaningfulDatabase.

#	Table Name	Domain Group	Rows	Meaningful Seeded Records Summary
1	organizations	Identity & Tenancy	2	Primary org code-sentinel (7d9e1f2a-3b4c-4d5e-8f60-718293a4b5c6, threshold 0.80) and tenant-isolated acme-payments (8e0f2a3b-..., threshold 0.85)
2	users	Identity & Tenancy	4	octo-dev (admin), priya-sec (admin), arjun-dev (member), and riley-acme (Acme Payments admin)
3	organization_members	Identity & Tenancy	4	Maps octo-dev, priya-sec, and arjun-dev to code-sentinel; maps riley-acme to acme-payments
4	organization_agent_defaults	Repositories & Config	5	5 agent defaults for code-sentinel: security=block, logic=block, performance=comment, style=comment, documentation=comment
5	github_installations	Identity & Tenancy	2	Installation #1 on code-sentinel (9a8b7c6d-...) and Installation #2 on acme-payments (a1b2c3d4-...)
6	github_user_tokens	Identity & Tenancy	2	AES-256-GCM SecretBox-sealed accessTokenSealed & refreshTokenSealed for octo-dev and arjun-dev
7	repositories	Repositories & Config	3	code-sentinel/consumer-api (TS), code-sentinel/checkout-service (Python), acme-payments/settlement-engine (TS)
8	repository_settings	Repositories & Config	3	Per-repo confidenceThresholdOverride (0.80, null, 0.85), agentTimeoutMs (20000ms, 25000ms), autoFixStyle, reviewBranches
9	repository_members	Repositories & Config	2	Grants member arjun-dev and admin priya-sec explicit repository access to code-sentinel/consumer-api

#	Table Name	Domain Group	Rows	Meaningful Seeded Records Summary
10	repository_agent_config	Repositories & Config	5	5 explicit per-agent mode rows on code-sentinel/consumer-api (useOrgDefaults=false)
11	reviews	Review Pipeline	4	PR #42 (completed/fail), PR #48 (partial/fail, Logic timed out), PR #51 (dashboard_manual completed/pass), PR #42 older SHA (cancelled)
12	agent_runs	Review Pipeline	15	5 runs on PR #42 (all succeeded, Perf fallback depth 1), 5 on PR #48 (4 succeeded, Logic timed_out), 5 on PR #51 (4 succeeded, Doc skipped)
13	findings	Review Pipeline	12	9 findings on PR #42 (including duplicate SQLi linked via duplicateOf), 2 on PR #48, 1 info docstring finding on PR #51
14	suggestions	Review Pipeline	6	Covers all 4 states (proposed, accepted, rejected, superseded) and both fixKind values (deterministic, ai_suggested)
15	finding_embeddings	Vector Store (pgvector)	4	768-dimension L2-normalized vector(768) embeddings (gemini-embedding-2) for SQLi and performance findings
16	finding_similarities	Vector Store (pgvector)	2	Links PR #48 SQLi -> PR #42 SQLi (score 0.924) and PR #48 retry loop -> PR #42 N+1 query (score 0.889)
17	session_activity	Security & Operations	3	Active sessions for octoLaptop, octoPhone, and arjunWorkstation with IP, userAgent, and lastSeenAt
18	audit_events	Security & Operations	10	10 immutable security audit events covering github_linked, repo_config_updated, fix_accepted/rejected, fixes_applied, review_rerun, session_revoked, step_up_refused
TOTAL	**18 PostgreSQL Tables**	**All 4 Domain Groups**	**88**	**100% schema coverage across all 18 Prisma models and all 9 PostgreSQL enum types**

3.3 Concrete Seeded Records by Domain Group

3.3.1 Identity, Multi-Tenancy, Repositories & Configuration (Tables 1–10)

- **Organizations (2 rows):** `code-sentinel` (`7d9e1f2a-3b4c-4d5e-8f60-718293a4b5c6`, default threshold 0.80) and tenant-isolated `acme-payments` (`8e0f2a3b-4c5d-4e6f-9a70-8293a4b5c6d7`, default threshold 0.85).
- **Users & Memberships (8 rows across users & organization_members):** `octo-dev` (Octo Dev, admin), `priya-sec` (Priya Sharma, Security Lead, admin), `arjun-dev` (Arjun Patel, member restricted via `repository_members` to `consumer-api`), and `riley-acme` (Riley Chen, Acme Payments admin).
- **Installations, Tokens, Repositories & Config (20 rows):** Two active GitHub App installations; two AES-256-GCM sealed OAuth token pairs; three repositories (`code-sentinel/consumer-api`, `code-sentinel/checkout-service`, `acme-payments/settlement-engine`); per-repo settings; 2 `repository_members` rows; 5 `organization_agent_defaults` rows; and 5 `repository_agent_config` override rows.

3.3.2 Reviews, Agent Runs, Findings, Suggestions & pgvector Context (Tables 11–16)

- **Review 1 — PR #42 on code-sentinel/consumer-api (completed / fail):** All 5 agents succeeded (Performance Agent recorded `llmProvider='gemini'` with `llmFallbackDepth=1`). Produced 9 raw findings (8 deduplicated primary findings + 1 child SQLi finding from Logic Agent collapsed into Security Agent's `CWE-89` finding via `duplicateOf` with `duplicateCount=2`). Includes 5 suggestions spanning `proposed`, `accepted` (with commit SHA & resolver user ID), and `rejected` (`will_fix_manually`).
- **Review 2 — PR #48 on code-sentinel/consumer-api (partial / fail):** Demonstrates NFR-04 graceful degradation: Security, Style, Performance, and Documentation succeeded while Logic Agent recorded

`status='timed_out'` at `latencyMs=20004`. Its SQLi and unbounded retry findings link via `finding_similarities` to PR #42's historical findings with cosine scores `0.924` and `0.889`.

- **Review 3 — PR #51 on code-sentinel/checkout-service (dashboard_manual / pass):** On-demand review triggered from the Web Dashboard with 1 non-blocking `info` docstring finding and `checkConclusion='pass'`.
- **Review 4 — Superseded PR #42 Commit (cancelled):** Demonstrates in-flight job cancellation when a newer commit is pushed to the same pull request.

3.3.3 Device Session Activity & Security Audit Trail (Tables 17–18)

- **Session Activity (3 rows):** Tracks active browser/OS sessions (`octoLaptop`, `octoPhone`, `arjunWorkstation`) with IPv4 addresses, User-Agent strings, and `lastSeenAt` timestamps.
- **Audit Events (10 rows):** Covers all 10 security-sensitive actions (`github_linked`, `installations_synced`, `review_defaults_updated`, `repo_config_updated`, `fix_accepted`, `fix_rejected`, `fixes_applied`, `review_rerun`, `session_revoked`, and `step_up_refused`) with correlation `requestId` and JSONB metadata.

3.4 Database Seeding & Constraint Verification Test Cases (DB-01 to DB-12)

Table 3.2 details the unit and PostgreSQL integration test cases in packages/db/src/seed-data.test.ts and packages/db/src/schema.integration.test.ts that validate the seeded dataset and database invariants.

Test ID	Verification Case	Execution Procedure	Expected Database Outcome	Status
DB-01	Full 18-Table Idempotent Seeding (seedMeaningfulDatabase)	Run npm run db:seed twice consecutively against PostgreSQL 16 + pgvector	Both runs succeed with 0 errors; record counts across all 18 tables equal exactly 88 rows without duplicate key errors	PASS
DB-02	Contract & Dev-Seed ID Alignment	Verify SEED_IDS in @code-sentinel/db match @code-sentinel/contracts/examples and dev-seed.ts	Organization (7d9e1f2a-...), User (3c4d5e6f-...), Installation (9a8b7c6d-...), and Repository (2b0c6b0e-...) UUIDs match 100%	PASS
DB-03	AES-256-GCM OAuth Token Encryption at Rest	Inspect github_user_tokens rows for octo-dev and arjun-dev and unseal with SecretBox	No plaintext token exists in DB; SecretBox.open() recovers exact ghu_/ghr_ tokens from sealed ciphertext	PASS
DB-04	Review Pipeline Foreign Keys & Deduplication Chain	Verify reviews -> agent_runs -> findings -> suggestions relational chain on PR #42	Finding pr42SqlInjectionOrders has duplicateCount=2 and child duplicate pr42SqlInjectionLogicDuplicate linked via duplicateOf	PASS
DB-05	Suggestion Lifecycle State Invariants	Inspect 6 seeded suggestions across proposed, accepted, rejected, and superseded states	Accepted suggestions have resolvedByUserId and githubCommitSha; rejected suggestion has rejectionReason='will_fix_manually'; superseded suggestion belongs to PR #48	PASS
DB-06	pgvector 768-Dimension Embedding Storage	Query finding_embeddings vector_dims(embedding) in PostgreSQL	All 4 rows in finding_embeddings have vector_dims(embedding) = 768 and embedding_model = 'gemini-embedding-2'	PASS
DB-07	pgvector Cosine Similarity Ranking (<=> operator)	Execute SELECT 1 - (e1.embedding <=> e2.embedding) AS score between cluster pairs	Same-cluster finding pairs (SQLi cluster 1, Perf cluster 2) yield cosine similarity > 0.88; cross-cluster < 0.20	PASS

Test ID	Verification Case	Execution Procedure	Expected Database Outcome	Status
DB-08	Cross-Tenant Isolation on Seeded Records	Query reviews, findings, and vector similarity scoped to code-sentinel vs acme-payments	code-sentinel queries never return acme-payments/settlement-engine; pgvector search filters by organization_id	PASS
DB-09	Repository Member Fine-Grained Access Control	Query repositories visible to arjun-dev (member) vs octo-dev (admin)	Admin octo-dev sees both code-sentinel repos; member arjun-dev sees only code-sentinel/consumer-api via repository_members	PASS
DB-10	Pull Request Review Unique Constraint (uq_reviews_pr_head)	Attempt to insert a second github_pull_request review for the same (repositoryId, prNumber, headSha)	PostgreSQL unique index uq_reviews_pr_head rejects duplicate PR review while allowing repeated dashboard_manual re-runs	PASS
DB-11	Audit Events & Session Activity Completeness	Query audit_events (10 rows) and session_activity (3 rows) for code-sentinel	All 10 security audit actions and 3 active device sessions are queryable with IP, userAgent, requestId, and JSONB metadata	PASS
DB-12	Clean Cascading Teardown (deleteSeededDatabase)	Invoke deleteSeededDatabase(prisma) after integration test suite	Deletes all 88 seeded records cleanly via cascading organization and user deletes without FK violations	PASS

4. Non-Functional Testing (UI, Performance, Reliability, Security & Observability)

4.1 Non-Functional Test Methodology

Non-functional testing validates that Code-Sentinel meets all 14 Non-Functional Requirements (NFR-01 through NFR-14) across its two client surfaces (GitHub App and Next.js Web Dashboard) and seven backend services:

- **UI / UX, Responsive Viewport & Accessibility Testing (NFT-UI-01..16):** Verified across Desktop (1440x900, 1920x1080), Tablet (768x1024), and Mobile (375x812) viewports, auditing WCAG 2.1 AA contrast ratios, keyboard navigation, hydration stability, SSE live progress rendering, and visual/data parity between GitHub PR Check Runs and the Web Dashboard.
- **Performance, Latency & Scalability Testing (NFT-PERF-01..06):** Measured end-to-end review duration (P50 = 6.4s, P95 = 18.2s vs. 60s target), 20s per-agent timeout enforcement, <5s Check Run creation, 10 concurrent review jobs, large-diff token planning, and pgvector cosine lookup latency.
- **Availability, Fault Tolerance & Cost Control (NFT-REL-01..05):** Verified graceful partial-review completion when an agent times out, automatic Groq -> Gemini failover, 80% free-tier QuotaBudget enforcement, Render sleeping-service wake-up handling, and zero-LLM deterministic Style Agent execution.
- **Security, Step-Up Auth, Tenant Isolation & Rate Limiting (NFT-SEC-01..09):** Verified constant-time HMAC-SHA256 webhook checks, live Supabase session checks, conditional TOTP step-up, cross-tenant 404 isolation, repository_members access control, AES-256-GCM encryption at rest, 3-tier rate limiting (HTTP 429 + Retry-After), and CSP headers.
- **Observability, Metrics & Audit Logging (NFT-OBS-01..03):** Verified Prometheus /metrics endpoints across all 7 services, pre-zeroed alert counters for Grafana Cloud increase() rules, structured Pino correlation logs, and real client IP capture behind Cloudflare + Render (GATEWAY_TRUST_PROXY=2).

4.2 Detailed Non-Functional Test Cases (NFT-UI, NFT-PERF, NFT-REL, NFT-SEC, NFT-OBS)

Test ID	Category	Test Scenario & Requirement Under Test	Measured Result / Verification Evidence	Status
NFT-UI-01	UI / UX	Overview Dashboard (/overview) KPI cards, Needs Your Attention queue, and Agent Health panel	Renders 4 KPI cards, blocked PR queue ordered by critical count, and live 5-agent health bars matching seeded data	PASS
NFT-UI-02	UI / UX	Repositories View (/repositories) search, language badges, and Add Repository flow	Lists installed repositories with primary language, active agent count, and 30-day acceptance rate	PASS
NFT-UI-03	UI / UX	Review History (/reviews) multi-criteria filtering (repository, status, severity, date range)	Filtering updates URL search params and table rows; zero matching rows displays clean empty state with reset action	PASS
NFT-UI-04	UI / UX	Pull Requests View (/pull-requests) & On-Demand 'Re-run review' button interaction	Clicking 'Re-run review' triggers POST /v1/reviews, shows progress toast, and navigates to live review screen	PASS
NFT-UI-05	UI / UX	Review In-Progress Screen with SSE live timer and 5-agent status cards	Displays elapsed timer, live agent completion badges, and 'View partial results' banner when an agent times out	PASS
NFT-UI-06	UI / UX	Combined Review Report Overview: verdict banner, 5-agent matrix, and priority finding queue	Clearly states 'Two critical findings block this merge' (for PR #482) and filters findings by agent and severity	PASS

Test ID	Category	Test Scenario & Requirement Under Test	Measured Result / Verification Evidence	Status
NFT-UI-07	UI / UX	Three-Panel Code Review View (files / unified or split diff / inline anchored findings)	Anchors finding cards to exact added diff lines with syntax highlighting and keyboard navigation (j/k next finding)	PASS
NFT-UI-08	UI / UX	Finding Detail & Fix Modal: evidence, CWE/rule provenance, similar past issues, Commit/Reject actions	Displays proposed diff patch, confidence score badge (e.g. 0.96), similar issue link (#477), and Commit/Dismiss buttons	PASS
NFT-UI-09	UI / UX	Repository Agent Configuration (/repositories/[id]/settings): per-agent toggles & validation	Admin can toggle agents on/off; attempting to turn off the last enabled agent shows inline error and disables save	PASS
NFT-UI-10	UI / UX	Confidence Threshold Override Slider & Provenance Badge	Slider adjusts threshold (50%..95%) with live preview of held-back suggestions and shows 'Repository override' vs 'Org default'	PASS
NFT-UI-11	Responsive UI	Mobile Viewport (375px x 812px) layout across Overview, Reviews, Report Detail, and Settings	No horizontal overflow (scrollWidth <= 375px); sidebar collapses into drawer; tables adapt to stacked cards	PASS
NFT-UI-12	Responsive UI	Tablet Viewport (768px x 1024px) & Desktop Viewport (1440px / 1920px) layout verification	Grid columns scale smoothly; three-panel code review collapses file tree into dropdown on tablet widths	PASS
NFT-UI-13	Accessibility	WCAG 2.1 AA color contrast and keyboard focus ring audit across dark/light surfaces	All text/badge combinations meet >= 4.5:1 contrast ratio; every interactive control has visible :focus-visible ring	PASS
NFT-UI-14	UI / UX	Signed-In Devices & Security Settings (/settings/security): optional TOTP enrolment & session revoke	Displays enrolled authenticator status, QR enrolment modal, and active devices list with 'Sign out device' button	PASS
NFT-UI-15	Cross-Surface Parity	Consistency between GitHub Check Run summary and Web Dashboard Combined Report (NFR-08)	Identical finding counts (2 critical, 4 warning, 2 info), agent statuses, and partial-run explanation across both surfaces	PASS
NFT-UI-16	Cross-Surface Parity	GitHub inline suggested-change comment formatting and multi-line range anchoring	GitHub ```suggestion block matches exact start_line..line span and suggestedCode shown in Dashboard	PASS
NFT-PERF-01	Performance	End-to-end review completion latency on typical PR (<500 changed lines, 5 agents in parallel)	P50 = 6.4s, P95 = 18.2s, Max = 24.5s — well within NFR-01 target of P95 <= 60s	PASS
NFT-PERF-02	Performance	Per-agent timeout enforcement (default 20,000ms) under simulated downstream stall	Orchestrator aborts stalled agent at 20.02s and finishes partial report in 21.1s without blocking pipeline	PASS
NFT-PERF-03	Performance	Webhook acknowledgement and initial GitHub Check Run creation latency (AC-01)	POST /webhooks/github responds 202 in 48ms; initial 'in_progress' Check Run posted on GitHub in 1.1s (< 5s target)	PASS
NFT-PERF-04	Scalability	Concurrent execution of 10 simultaneous pull request review jobs (NFR-03)	All 10 jobs complete with 0 dropped requests, 0 unhandled rejections, and P95 latency = 27.8s	PASS
NFT-PERF-05	Performance	Large-diff token planner on 60-file PR (binary/lockfile dropping & import-graph batching)	Planner completes in <35ms, drops lockfiles/binaries, batches imports, and caps per-agent budget at 80K tokens	PASS
NFT-PERF-06	Performance	pgvector cosine similarity top-5 query latency on finding_embeddings	Query executes in 4.2ms (P95 < 12ms) scoped by organization_id	PASS

Test ID	Category	Test Scenario & Requirement Under Test	Measured Result / Verification Evidence	Status
NFT-REL-01	Reliability	Graceful degradation when 1 to 4 agents time out or return HTTP 500 (NFR-04)	Review completes with status='partial' as long as >= 1 agent succeeds; only marks status='failed' if all 5 fail	PASS
NFT-REL-02	Reliability	Automatic LLM provider failover from Groq (openai/gpt-oss-120b) to Gemini 3.5 Flash Lite	On Groq 429/5xx/timeout, LlmClient switches to Gemini within 150ms and records llmFallbackDepth=1	PASS
NFT-REL-03	Cost / Quota	QuotaBudget 80% free-tier cap enforcement under sustained burst load (NFR-14)	Zero upstream 429 errors from Groq or Gemini; excess load defers to secondary provider or marks llm_quota_exhausted	PASS
NFT-REL-04	Reliability	Render free-tier sleeping agent cold-start wake-up and calm dashboard status	Health probe reports 'sleeping' when idle; next review automatically wakes service and completes	PASS
NFT-REL-05	Reliability	Zero-LLM determinism of Style Agent auto-fixes (NFR-07)	Running Style Agent 50 times on identical TS/Python diffs produces byte-for-byte identical patches with 0 LLM calls	PASS
NFT-SEC-01	Security	Webhook HMAC-SHA256 verification before body parsing & constant-time comparison (NFR-05)	Rejects unsigned, replayed, or 1-byte modified webhook payloads with 401 before JSON deserialization	PASS
NFT-SEC-02	Security	Supabase JWT signature verification + live session revocation check on every Gateway request	Revoking a session immediately invalidates in-flight bearer tokens on the very next API request (401)	PASS
NFT-SEC-03	Security	Conditional TOTP step-up authentication on critical mutations (accept fix, update repo config)	Users with enrolled TOTP must supply a valid 6-digit code or aal2 session; unenrolled users are not locked out	PASS
NFT-SEC-04	Security	No autonomous branch modification guarantee (FR-GH-04)	Review pipeline only creates Check Runs and PR comments; Git commits occur solely on POST .../suggestion/accept	PASS
NFT-SEC-05	Data Privacy	Cross-organization tenant isolation across all read and write endpoints (NFR-13)	Org 1 token requesting Org 2 review, finding, or repository receives 404 Not Found with zero data leakage	PASS
NFT-SEC-06	Security	Intra-organization repository permission isolation via repository_members	Organization member without repository permission on a private repo cannot list or view its reviews	PASS
NFT-SEC-07	Security	Encryption at rest for GitHub user tokens and secret redaction in logs/findings	OAuth tokens stored encrypted with AES-256-GCM; detected secrets in diffs are masked in findings and Pino logs	PASS
NFT-SEC-08	Security	3-tier rate limiting (per-installation webhook, per-user API, per-IP auth failure)	Exceeding threshold returns HTTP 429 with Retry-After header and writes rate_limit.exceeded to audit_events	PASS
NFT-SEC-09	Security	Content Security Policy (CSP), X-Frame-Options, and strict CORS headers on Dashboard & Gateway	Dashboard emits strict CSP headers; Gateway restricts CORS to configured dashboard origin	PASS
NFT-OBS-01	Observability	Prometheus /metrics exposition across Gateway, Orchestrator, and all 5 Agent services	All 7 services expose http_requests_total, http_request_duration_seconds, and service-specific metrics	PASS

Test ID	Category	Test Scenario & Requirement Under Test	Measured Result / Verification Evidence	Status
NFT-OBS-02	Observability	Grafana Cloud dashboard (docs/monitoring/code-sentinel.json) & alert rules (alerts.yaml)	Grafana panels render request rate, P95 latency, review outcomes, and LLM quota; alerts fire on agent failure/quota	PASS
NFT-OBS-03	Observability	Structured Pino logs with request correlation ID (X-Request-Id) & real client IP behind Cloudflare/Render	Every log line and audit_events row carries requestId, userId, and real client IP via GATEWAY_TRUST_PROXY=2	PASS

5. Bug Logs & Defect Resolution Tracking

5.1 Defect Triage Workflow & Severity Summary

Throughout unit testing, service integration, staging deployment on Render/Vercel/Supabase, and the team-wide bug-fixing rota, defects were logged, triaged by severity, resolved via atomic commits, and locked in with dedicated regression tests so they cannot recur.

Severity Level	Definition	Logged Count	Resolved & Verified	Open Count
Critical	Service crash, deployment boot failure, sandbox failure, or framework security advisory	3	3 (100%)	0
High	Broken workflow, auth/step-up defect, tenant leakage, stale PR suggestions, or proxy IP bug	10	10 (100%)	0
Medium	Duplicate findings, inaccurate UI badge counts, hydration warning, or metric initialization gap	8	8 (100%)	0
Low	Cosmetic or message-formatting issue with no functional or security impact	1	1 (100%)	0
TOTAL	**All Logged Defects Across M5, M6, and M7 Testing Cycles**	**22**	**22 (100%)**	**0**

5.2 Comprehensive Bug Log (BUG-01 to BUG-22)

Table 5.2 documents all 22 defects discovered during development and testing, including the affected component, severity, symptom and root cause analysis, exact Git commit SHA(s) that resolved the issue, and the automated regression test suite verifying the fix.

Bug ID	Component	Severity	Symptom & Root Cause Analysis	Resolution, Fix Commit & Regression Test	Status
BUG-01	llm (gemini-provider.ts)	**High**	Symptom: Gemini fallback calls occasionally hung past the review job's remaining time budget. Root Cause: GeminiProvider used a static HTTP timeout instead of forwarding the caller's remaining deadline AbortSignal.	Wired AbortSignal.any([timeoutSignal, callerSignal]) into Gemini HTTP calls (commit 723b5d0); verified in llm-client.test.ts.	**Closed**
BUG-02	orchestrator (finding-aggregator.ts)	**Medium**	Symptom: Repeated LLM passes reported the same logical issue 1-2 lines apart, creating duplicate comments. Root Cause: Deduplication initially required exact (lineStart, lineEnd) equality rather than overlapping or +/-2-line proximity within the same CWE/rule family.	Updated aggregator to collapse findings in the same CWE family or rule category on overlapping/adjacent lines (commits ef2d497, 0aacc15); tested in finding-aggregator.test.ts.	**Closed**
BUG-03	agent-kit (patch.ts)	**High**	Symptom: ESLint reported false syntax errors when linting extracted JavaScript/TypeScript diff hunks. Root Cause: Partial diff hunks cut inside function bodies had unbalanced opening/closing braces before whole-file linting was introduced.	Added brace-balancing recovery in patch.ts (commit 7a4fce3) and upgraded pipeline to send whole changed files (commits 57639b8, 87fc35d).	**Closed**

Bug ID	Component	Severity	Symptom & Root Cause Analysis	Resolution, Fix Commit & Regression Test	Status
BUG-04	security-agent (agent.ts)	Medium	Symptom: Security Agent emitted two findings on the same SQL query when SAST flagged CWE-89 and the LLM pass flagged CWE-564. Root Cause: Intra-agent deduplication compared raw CWE strings instead of canonical CWE families.	Added cweFamilyOf() in @code-sentinel/contracts and merged sibling-CWE findings in security-agent (commit 66ce5bc); tested in agent.test.ts.	Closed
BUG-05	security-agent (secrets.ts)	Low	Symptom: Secret scanner finding description echoed a slice of the matched secret value in its message text. Root Cause: Finding template interpolated the matched regex token directly instead of masking it.	Redacted matched secret literals in finding titles and descriptions (commit 3266047); verified in scan.test.ts.	Closed
BUG-06	dashboard (review-table.tsx)	Medium	Symptom: React hydration mismatch warning in browser console when rendering review timestamps on /pull-requests. Root Cause: Server rendered relative time ('2m ago') at SSR time which differed by 1 second on client hydration.	Deferred relative timestamp ticks to a client-side mounted hook with deterministic UTC fallback (commit 6939dd7); verified on /pull-requests.	Closed
BUG-07	gateway (github-webhook.ts)	High	Symptom: Pushing a second commit to an open PR while a review was still running left the older review's suggestions in proposed state. Root Cause: Starting a new review did not cancel the in-flight job for that PR or mark older open suggestions as superseded.	Added active-review lookup per PR, cancelled superseded jobs on push, and transitioned older open suggestions to superseded (commits 585767a, 2960098, 592b9ce).	Closed
BUG-08	gateway (octokit-github-client.ts)	High	Symptom: Committing a multi-line AI suggestion from the dashboard replaced only the last line of the comment range. Root Cause: GitHub review comment reader read line without reading start_line for multi-line review comments.	Updated octokit-github-client.ts to read start_line ?? line when resolving comment spans (commit 7df1209); tested in octokit-github-client.test.ts.	Closed
BUG-09	gateway (apply-all-fixes.ts)	Medium	Symptom: 'Apply all fixes (N)' button label showed a higher count than the number of fixes actually committed when two fixes touched overlapping lines. Root Cause: Button badge counted all proposed suggestions rather than pre-filtering non-overlapping, applicable fixes.	Filtered count to only non-overlapping fixes whose target lines still match the head file (commit a031ade); tested in apply-all-fixes.test.ts.	Closed

Bug ID	Component	Severity	Symptom & Root Cause Analysis	Resolution, Fix Commit & Regression Test	Status
BUG-10	gateway (review-output.ts)	Medium	Symptom: Check Run summary reported an inaccurate count of suggestions held back below the confidence threshold. Root Cause: Threshold summary counted findings without suggestions as 'held back' alongside findings whose suggestions were stripped by thresholdNode.	Counted only findings that carried a candidate suggestion before threshold filtering (commit 908714a); tested in review-output.test.ts.	Closed
BUG-11	db / gateway (prisma-stores.ts)	High	Symptom: GET /v1/me/sessions failed with a PostgreSQL column type error on production Supabase. Root Cause: auth.sessions.ip in Supabase is typed as inet, whereas the gateway expected text from private.user_sessions().	Cast host(s.ip) to text in private.user_sessions and aligned the Prisma raw query decoder (commit aacbeed); tested in sessions.test.ts.	Closed
BUG-12	style-agent (sandbox.ts)	Critical	Symptom: Style Agent failed on Render because Render containers do not expose a Docker daemon (/var/run/docker.sock). Root Cause: StyleAgent defaulted to spawning a sibling Docker container, which is unsupported inside Render's container runtime.	Added SANDBOX_MODE=process (ProcessSandbox) bundling ESLint, Prettier, Ruff, and Black inside the Style Agent Docker image with per-request temp dir isolation (commit cfa8535).	Closed
BUG-13	gateway (render/gateway.yaml)	Critical	Symptom: First production boot of the Gateway on Render exited before starting the HTTP server. Root Cause: Start command path and Prisma CLI invocation did not run migrate:deploy from the @code-sentinel/db workspace before booting dist/server.js.	Updated Render start script to run npm run migrate:deploy -w @code-sentinel/db followed by node services/gateway/dist/server.js (commits f792c5e, 5be12d3).	Closed
BUG-14	dashboard (package.json)	Medium	Symptom: Vercel production build failed compiling Tailwind CSS v4 native bindings on Linux x64. Root Cause: Transitive lightningcss version mismatch in lockfile lacked the Linux gnu binary pin.	Pinned lightningcss across workspace builds so Vercel's Linux build image resolves native binaries cleanly (commits 3d713ca, 81a4fac).	Closed
BUG-15	orchestrator (agents-health.ts)	Medium	Symptom: Dashboard displayed an alarming 'Agents degraded' banner whenever free-tier Render agents went to sleep after 15 minutes of inactivity. Root Cause: Health check treated Render's sleeping-service response as a hard service failure instead of an expected idle state.	Classified sleeping Render agents as status: 'sleeping' and rendered a calm 'Asleep (wakes automatically on next review)' notice (commit 7727d83).	Closed

Bug ID	Component	Severity	Symptom & Root Cause Analysis	Resolution, Fix Commit & Regression Test	Status
BUG-16	dashboard (supabase/server.ts)	High	Symptom: Sign-in and token refresh requests to Supabase Auth failed when the dashboard forwarded the browser's x-forwarded-for header. Root Cause: Supabase's Cloudflare edge rejected non-standard forwarded IP headers from Vercel serverless functions.	Stopped forwarding the browser IP to Supabase while continuing to forward it to the Gateway for session_activity and audit_events (commits a846c2e, 01045de).	Closed
BUG-17	gateway (config.ts)	High	Symptom: Audit log and Signed-in Devices on production recorded Render's internal Cloudflare proxy IP instead of the user's real IP. Root Cause: GATEWAY_TRUST_PROXY was set to 1, but traffic to api.codesentinel.scribly.fun traverses 2 proxy hops (Cloudflare + Render LB).	Configured GATEWAY_TRUST_PROXY=2 in render/gateway.yaml and added multi-hop proxy tests (commit fc7ab84); verified in audit-log.test.ts.	Closed
BUG-18	service-kit (metrics.ts)	Medium	Symptom: Grafana Cloud increase() alert rules missed the very first agent failure or quota event after a service restart. Root Cause: prom-client labeled counters only appear in /metrics after their first increment, so Prometheus saw a missing series rather than 0 -> 1.	Pre-initialized all alert counter label combinations to 0 at service startup (commit a2751fa); tested in metrics.test.ts.	Closed
BUG-19	dashboard (env.ts)	High	Symptom: Vercel preview/production builds baked the default localhost Gateway URL if GATEWAY_URL was changed without a full rebuild. Root Cause: Module-scope constant evaluated process.env.GATEWAY_URL at bundle initialization time.	Changed gatewayUrl() to read process.env dynamically at request time (commit 9ece78f); tested in env.test.ts.	Closed
BUG-20	gateway (repositories.ts)	High	Symptom: An organization member who collaborated on only one GitHub repository of an account could see other repositories of that installation in the dashboard. Root Cause: Repository listing checked organization membership without intersecting against the user's GitHub repository permissions.	Added repository_members table populated at installation sync and restricted member queries to their permitted repositories (commits 2732660, c6e3802).	Closed
BUG-21	gateway / dashboard (guards.ts, mfa.ts)	High	Symptom: Users who had not enrolled an authenticator app were blocked from saving repository settings, and enrolled users were asked for a TOTP code on every sign-in. Root Cause: Step-up guard unconditionally required aal2 even when private.user_has_totp(user_id) was false.	Made authenticator enrolment optional: requireStepUp checks userHasAuthenticator(userId) first, and codes are requested only before critical actions (commits b0d8193, 1d9a877, f12040f, cb18d1b).	Closed

Bug ID	Component	Severity	Symptom & Root Cause Analysis	Resolution, Fix Commit & Regression Test	Status
BUG-22	dashboard (next)	Critical	Symptom: Security advisory published affecting Next.js 16.4.0 middleware/request handling. Root Cause: Upstream framework vulnerability in next@16.4.0.	Upgraded next and eslint-config-next from 16.4.0 to patched 16.4.3 across apps/dashboard and verified all routes and CSP headers (commit ac8f32b).	Closed

5.3 Document Sign-Off

This Test Plan and Test Cases deliverable (Milestone M7) has been executed and verified against the automated CI test suite (67 test files, 868 passing tests across Node.js 22 and Node.js 24), the 18-table PostgreSQL + pgvector seed dataset, and the live production deployment at https://codesentinel.scribly.fun by all eight members of Team Code-Sentinel.